

Безпека операційних систем

Історія Windows

Дискова операційна система (DOS) – це операційна система, яку комп'ютер використовує, щоб ці пристрої зберігання даних могли читати і записувати файли. DOS надає файлову систему, яка організовує файли на диску певним способом. Компанія Microsoft викупила DOS і розробила MS-DOS. MS-DOS використовувала командний рядок як інтерфейс для створення програм і роботи з файлами даних, як показано в протоколі результату виконання команди. Команди DOS відображаються жирним текстом.

```
Starting MS-DOS...
HIMEM is testing extended memory... done.
C:\> C:\DOS\SMARTDRV.EXE /X
C:\> dir
Volume in drive C is MS-DOS_6
Volume Serial Number is 4006-6939
Directory of C:\
DOS  <DIR>  05-06-17  1:09p
COMMAND  COM   54,645  05-31-94  6:22a
WINA20   386    9,349  05-31-94  6:22a
CONFIG   SYS    71 05-06-17  1:10p
AUTOEXEC BAT    78 05-06-17  1:10p
5 file(s) 64,143 bytes
517,021,696 bytes free
C:\>
```

За допомогою MS-DOS комп'ютер розумів, як отримати доступ до дисководу, і завантажити файли операційної системи безпосередньо з диска в процесі завантаження. Після завантаження MS-DOS могла легко отримати доступ до диска, оскільки він був вбудований в операційну систему.

Перші версії Windows мали графічний інтерфейс користувача (GUI), який працював під управлінням MS-DOS, починаючи з Windows 1.0 у 1985 році. Дискова операційна система все ще управляла комп'ютером та його апаратним забезпеченням. Сучасна операційна система, як-от Windows 10, не вважається дисковою операційною системою. Вона побудована на Windows NT, що означає Нові технології (New Technologies). Операційна система безпосередньо керує комп'ютером та його апаратним забезпеченням. NT – є ОС із підтримкою декількох процесів користувача. Це є значною відмінністю від однопроцесної, користувацької MS-DOS.

Команда MS-DOS	Опис
dir	Показує список усіх файлів у поточному каталозі (папці)
cd directory	Змінює теку на вказаний теку
cd ..	Змінює теку на теку вище поточного теки
cd \	Змінює теку на кореневу (часто C:)
copy source	Копіює файли в інше місце
del filename	Видалення одного або кількох файлів
find	Шукає текст у файлах
mkdir directory	Створює нову теку
ren oldname newname	Перейменовує файл
help	Відображає всі команди, які можна використовувати, з коротким описом
help command	Відображає розширену довідку для вказаної команди

Версії Windows

З 1993 року було створено більше 20 версій Windows, які засновані на операційній системі NT. Більшість цих версій були призначені для приватних користувачів та підприємств завдяки безпеці файлів, що забезпечується файловою системою в операційній системі NT. Великі компанії також почали використовувати операційні системи на базі Windows NT. Це пов'язано з тим, що багато версій було створено спеціально для робочих станцій, професійних, серверних, просунутих серверів і серверів центрів обробки даних, і це лише деякі з безлічі спеціалізованих версій.

Починаючи з Windows XP, стала доступна 64-розрядна версія. 64-розрядна операційна система була цілком новою архітектурою. Вона мала 64-розрядний адресний простір замість 32-розрядного адресного простору. Це не просто вдвічі більша кількість простору (оскільки ці біти є двійковими числами). У той час як 32-бітна Windows може використовувати трохи менше 4 Гб оперативної пам'яті, 64-бітна Windows теоретично може використовувати 16,8 мільйона терабайт. Якщо операційна система та все апаратне забезпечення підтримують 64-розрядні операції, то можуть оброблятися надзвичайно великі обсяги даних. Ці великі набори даних містять великі бази даних, наукові обчислення та обробку цифрового відео високої чіткості зі спеціальними ефектами. Загалом, 64-розрядні комп'ютери та операційні системи сумісні зі старими 32-розрядними програмами, але 64-розрядні програми не можуть виконуватися на старому 32-бітному апаратному забезпеченні.

Уразливості Windows OS

Захист від вірусів або шкідливих програм

- За замовчуванням Windows використовує Захисник Windows для захисту від шкідливих програм.
- Служба Windows Defender надає набір засобів захисту, вбудованих у систему.
- Якщо Windows Defender вимкнений, система стає більш уразливою до атак та зловмисного програмного забезпечення.

Невідомі або некеровані служби

- Існує безліч служб, які працюють в фоновому режимі.
- Важливо переконатися, що кожен сервіс є ідентифікованим та безпечним.
- Якщо в фоновому режимі працює невідомий сервіс, комп'ютер може бути вразливим до атак.

Шифрування

- Коли дані не зашифровані, їх можна легко зібрати і використати.
- Це важливо не тільки для настільних комп'ютерів, але і для мобільних пристроїв.

Політика безпеки

- Потрібно налаштувати і дотримуватись правильної політики безпеки.
- Багато параметрів в елементі управління політикою безпеки Windows можуть запобігти атакам.

Міжмережний екран

- За замовчанням Windows використовує брандмауер Windows для обмеження обміну даними з пристроями в мережі.
- Згодом правила можуть більше не застосовуватися.
- Наприклад, користувачі можуть залишити відкритим порт, який не повинен бути постійно доступний.

Права доступу до файлів

- Ці права повинні бути встановлені правильно.
- Найпростіше дати групі «Всі» повний доступ, але це дозволяє всім користувачам робити те, що вони хочуть, зі всіма файлами.
- Найкраще надати кожному користувачеві або групі мінімально необхідні права для всіх файлів та папок.

Слабкий пароль або його відсутність

- Багато користувачів вибирають слабкі паролі або взагалі не використовують пароль.
- Особливо важливо переконатися, що всі облікові записи, особливо обліковий запис адміністратора, мають дуже надійний пароль.

Вхід в систему як адміністратор

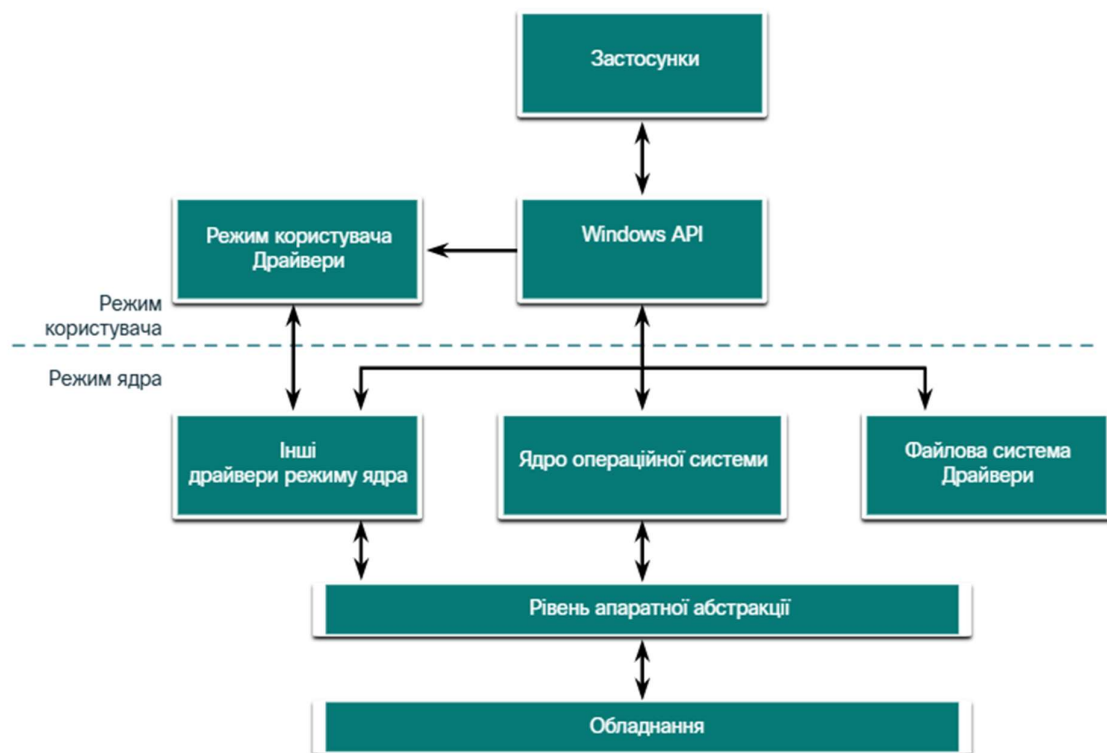
- Коли користувач входить в систему як адміністратор, будь-яка запущена їм програма матиме права цього облікового запису.
- Краще увійти у систему як стандартний користувач і використовувати пароль адміністратора для виконання певних завдань.

Рівень апаратної абстракції

Комп'ютери з Windows використовують багато різних пристроїв апаратного забезпечення. Операційну систему можна встановити як на придбаний комп'ютер, так і на комп'ютер, зібраний користувачем. Коли операційна система встановлена, вона не повинна залежати від можливих змін в апаратному забезпеченні. Базову архітектуру Windows показано на рисунку.

Рівень апаратної абстракції (Hardware Abstraction Layer, HAL) – це код, який обробляє весь обмін даними між апаратним забезпеченням та ядром (Kernel).

Як зображено на рисунку, існує два різних режими роботи центрального процесора, коли на комп'ютері встановлено ОС Windows: режим користувача та режим ядра.



Встановлені програми запускаються в режимі користувача, а код операційної системи працює в режимі ядра. Код, який виконується в режимі ядра, має необмежений доступ до базового апаратного забезпечення і здатний виконувати будь-які інструкції CPU. Код режиму ядра також може посилатися на будь-яку адресу пам'яті безпосередньо. Для найбільш критичних функцій ОС в коді, що запускаються в режимі ядра, передбачена можливість, що при збої в коді буде зупинена робота всього комп'ютера.

Файлові системи Windows

exFAT

- Це проста файлова система, яка підтримується багатьма різними операційними системами.
- FAT має обмеження на кількість розділів, розміри розділів та файлів, які може адресувати, тому вона більше не використовується для жорстких дисків (HD) або твердотілих накопичувачів (SSD).
- Можна використовувати і FAT16, і FAT32, але FAT32 є найбільш поширеною, оскільки вона має набагато менше обмежень, ніж FAT16.

Ієрархічна файлова система Plus (HFS+)

- Ієрархічна файлова система плюс (HFS+) використовується на комп'ютерах MAC OS X і дозволяє застосовувати набагато довші імена файлів, розміри файлів та розміри розділів, ніж попередні файлові системи.
- Хоча вона не підтримується Windows без спеціального програмного забезпечення, Windows може читати дані з розділів HFS+.

Розширена файлова система (EXT)

- Розширена файлова система (EXT) використовується на комп'ютерах під керуванням Linux.
- Хоча вона не підтримується Windows, Windows може читати дані з розділів EXT за допомогою спеціального програмного забезпечення.

Файлова система нової технології (NTFS)

- Файлова система нової технології (NTFS) - найпоширеніша файлова система при інсталяції Windows. Усі версії Windows і Linux підтримують NTFS.
- Комп'ютери Mac-OS X можуть читати лише розділ NTFS. Вони можуть виконувати запис у розділ NTFS після встановлення спеціальних драйверів.

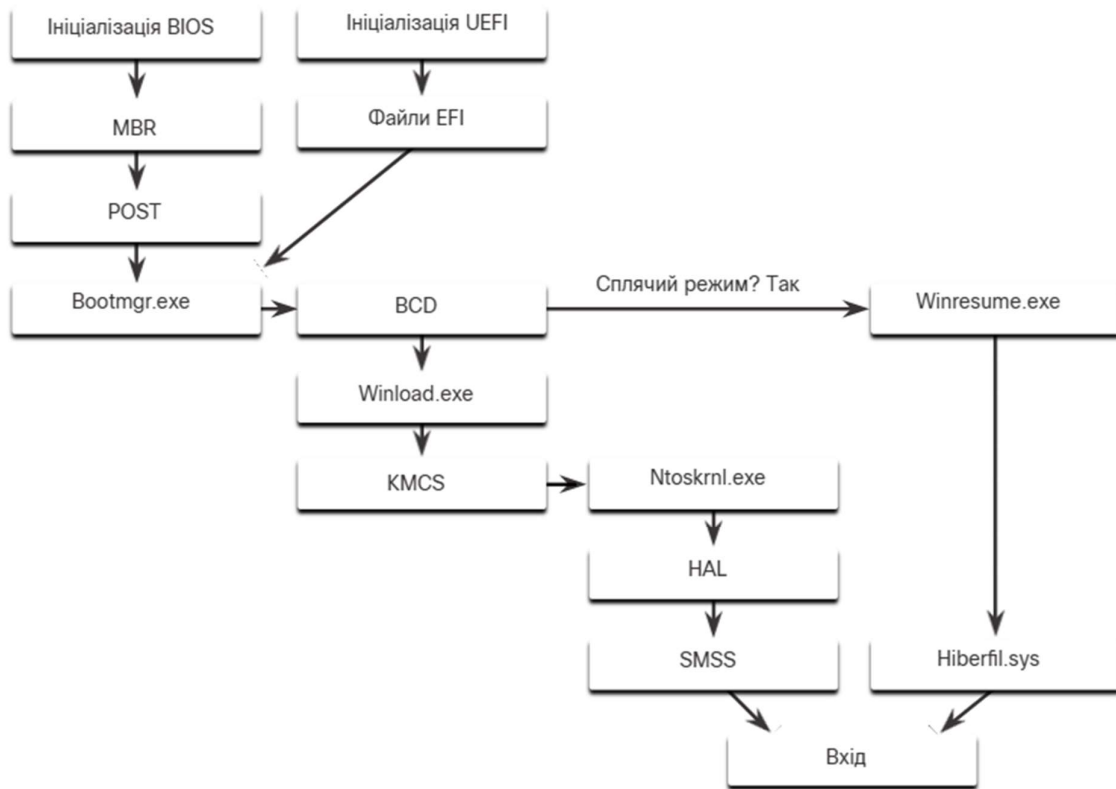
NTFS є найпоширенішою файловою системою для Windows з багатьох причин. NTFS підтримує дуже великі файли та розділи, а також добре сумісна з іншими операційними системами.

Форматування NTFS створює важливі структури на диску для зберігання файлів, а також таблиці для запису розміщення файлів:

- Розділ завантажувального сектора – це перші 16 секторів диска. Він містить розміщення головної таблиці файлів (Master File Table, MFT). Останні 16 секторів містять копію завантажувального сектора.
- Головна таблиця файлів – ця таблиця містить розташування всіх файлів і каталогів розділу, а також атрибути файлів, як-от інформація про безпеку та мітки часу.
- Файлова область – це основна область розділу, де зберігаються файли та каталоги.

Процес завантаження Windows

Багато дій відбувається між моментом натиснення кнопки живлення комп'ютера і повним завантаженням ОС Windows, як показано на рисунку.



Існує два типи прошивки комп'ютера:

Базова система введення-виведення (Basic Input-Output System - BIOS)

Мікропрограмне забезпечення (прошивка) BIOS було створено на початку 1980-х років і досі працює так само, як і тоді, коли воно було створено.

Уніфікований розширений інтерфейс прошивки (Unified Extended Firmware Interface - UEFI)

UEFI було розроблено для заміни BIOS та підтримки нових функцій.

У мікропрограмному забезпеченні BIOS процес починається з етапу ініціалізації BIOS. Це відбувається тоді, коли ініціалізуються апаратні пристрої та виконується самотестування при вмиканні живлення (POST), щоб переконатися, що всі ці пристрої можуть обмінюватися даними. При виявленні системного диску POST завершується. Останньою інструкцією в POST є пошук головного завантажувального запису (Master Boot Record, MBR).

Запуск Windows

Існує два важливих елементи реєстру, які використовуються для автоматичного запуску програм та служб:

- **HKEY_LOCAL_MACHINE** — в цьому розділі зберігаються кілька аспектів конфігурації Windows, а саме інформацію про служби, які запускаються при кожному завантаженні.
- **HKEY_CURRENT_USER** — в цьому розділі зберігаються декілька аспектів, пов'язаних із входом користувача, а саме інформацію про служби, які завантажуються тільки тоді, коли цей користувач входить в систему на комп'ютері.

Різні записи в цих місцях реєстру визначають, які служби та програми будуть запускатися відповідно до типу запису. До таких типів відносяться Run, RunOnce, RunServices, RunServicesOnce і Userinit. Ці записи можна ввести в реєстр вручну, але набагато безпечніше використовувати інструмент Msconfig.exe.

Реєстр Windows

Windows зберігає всю інформацію про апаратне забезпечення, застосунки, користувачів і налаштування системи у великій базі даних, відомій як реєстр. Значення, в яких зберігаються дані, це ключі та підключі. Ключ реєстру може мати глибину до 512 рівнів.

HKEY_CURRENT_USER (HKCU)

Зберігає інформацію про користувача, який зараз увійшов у систему.

HKEY_USERS (HKU)

Містить дані, що стосуються всіх облікових записів користувачів на хості.

HKEY_CLASSES_ROOT (HKCR)

Містить дані про під'єднані та вбудовуванні об'єкти (OLE). OLE дозволяє користувачам вставляти об'єкти з інших програм (наприклад, електронну таблицю) в один документ (наприклад, документ Word).

HKEY_LOCAL_MACHINE (HKLM)

Зберігає інформацію, пов'язану з системою.

HKEY_CURRENT_CONFIG (HKCC)

Містить дані про поточний профіль апаратного забезпечення.

Нові гілки не можна створювати. У гілках реєстру можна створювати ключі та їх значення, змінювати або видаляти їх за допомогою облікового запису з правами адміністратора. Як показано на рисунку, для зміни реєстру використовується інструмент **regedit.exe**. Будьте обережні, застосовуючи цей інструмент. Незначні зміни у реєстрі можуть мати серйозні або навіть катастрофічні наслідки.

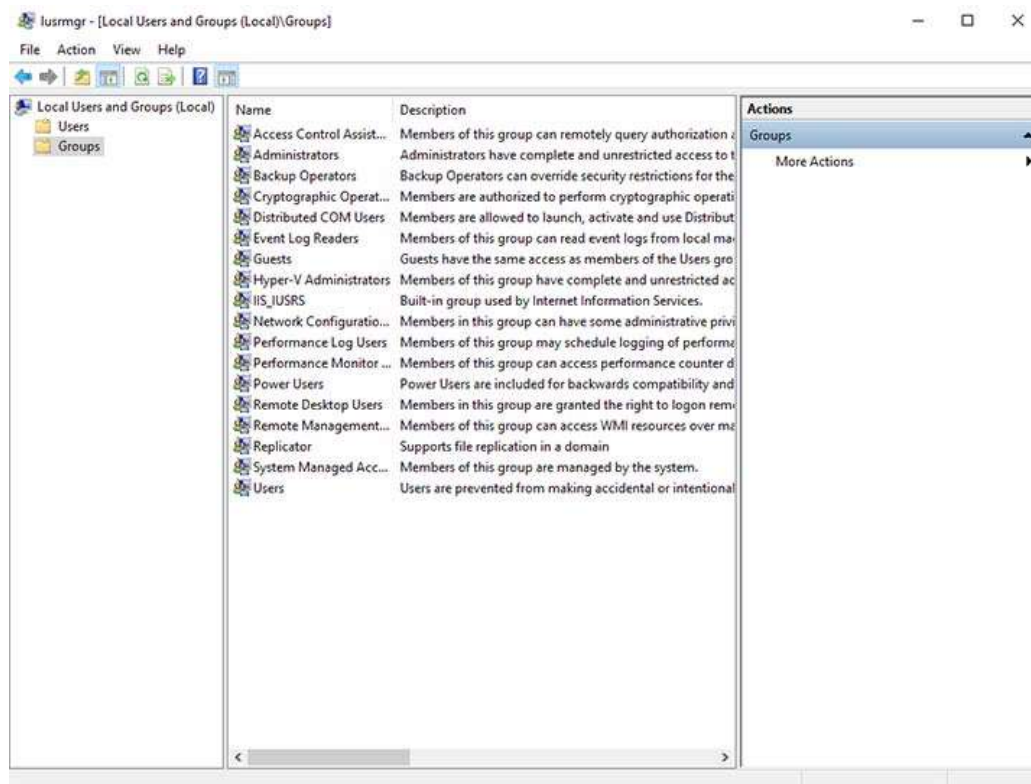
Запуск від імені адміністратора

З міркувань безпеки не рекомендується входити у Windows за допомогою облікового запису адміністратора або облікового запису з правами адміністратора. Це пов'язано з тим, що будь-яка програма, яка виконується під час входу з цими правами, успадковує їх. Шкідливе ПЗ, що має адміністративні права, має повний доступ до всіх файлів і папок на комп'ютері.

Локальні користувачі та домени

Коли ви вперше вмикаєте новий комп'ютер або інстальєте Windows, вам буде запропоновано створити обліковий запис користувача. Він має назву – локальний користувач. Цей обліковий запис буде містити всі ваші параметри налаштування, права доступу, розташування файлів і багато інших даних, що відносяться до користувача.

Для полегшення адміністрування користувачів в Windows використовуються групи. Кожна група має назву та пов'язаний із нею певний набір дозволів. Коли користувач розміщується в групі, йому надаються дозволи цієї групи. Для надання користувачеві багатьох різних прав, його можна розмістити в декількох групах. Керування локальними користувачами та групами виконується за допомогою застосунку панелі керування `lusrmgr.msc`, як показано на рисунку.



Інтерфейс командного рядка та PowerShell

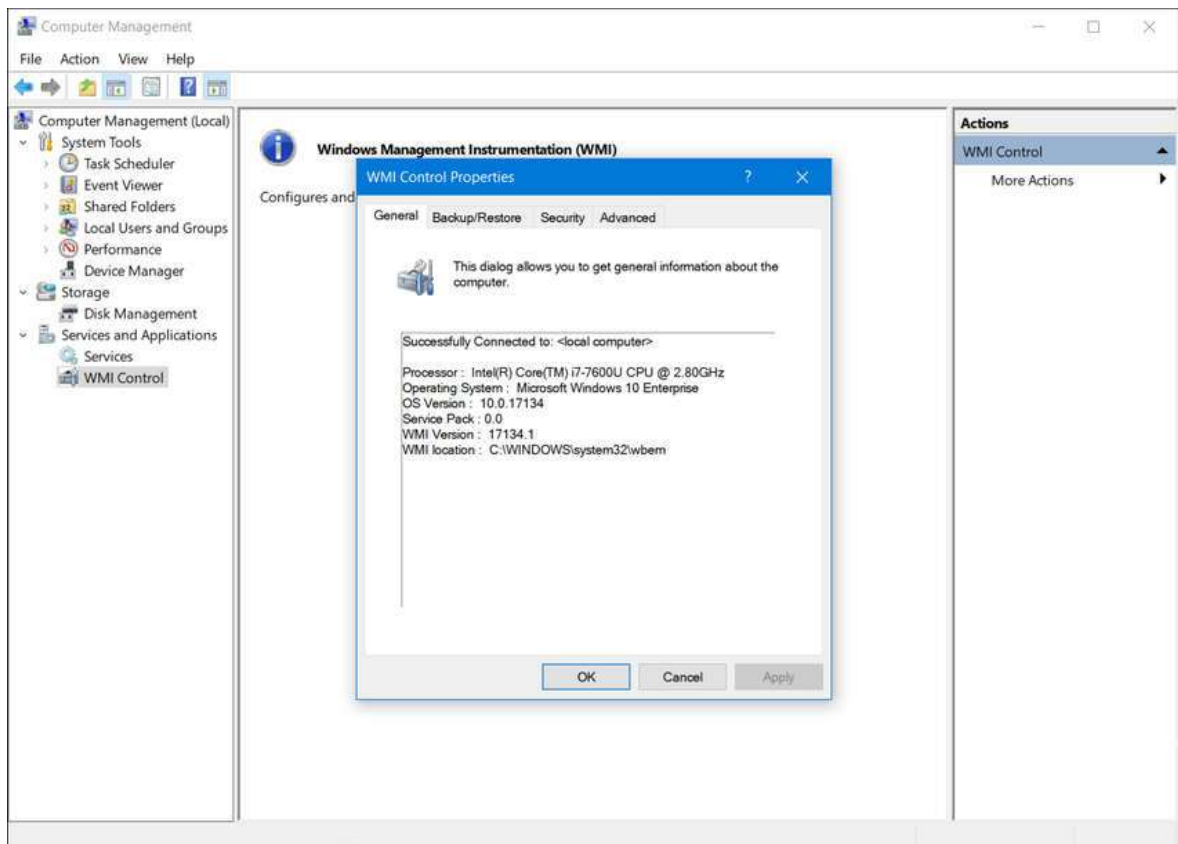
Інтерфейс командного рядка Windows (Command Line Interface, CLI) може використовуватися для запуску програм, навігації в файловій системі та керування файлами і папками.

Нижче наведено типи команд, які може виконувати PowerShell:

- cmdlets – ці команди виконують дію і повертають результат в наступну команду, яка буде виконуватися.
- PowerShell scripts – це файли з розширенням .ps1, які містять команди PowerShell, що виконуються.
- PowerShell functions – це фрагменти коду, на які можна посилатися у скрипті.

Інструментарій керування Windows

Інструментарій керування Windows (Windows Management Instrumentation, WMI) використовується для керування віддаленими комп'ютерами. Він може отримувати інформацію про компоненти комп'ютера, статистику апаратного і програмного забезпечення та відслідковувати стан віддалених комп'ютерів.



Linux



Linux (Linus + Unix) – це операційна система, яка була створена у 1991 році. ОС Linux має відкритий вихідний код (open source), ОС Linux – швидка, надійна та невелика. Вона є дуже невимогливою до апаратних ресурсів для роботи та має широкі можливості налаштування. На відміну від інших операційних систем, як-от Windows і Mac OS X, Linux була створена і зараз підтримується спільнотою програмістів.

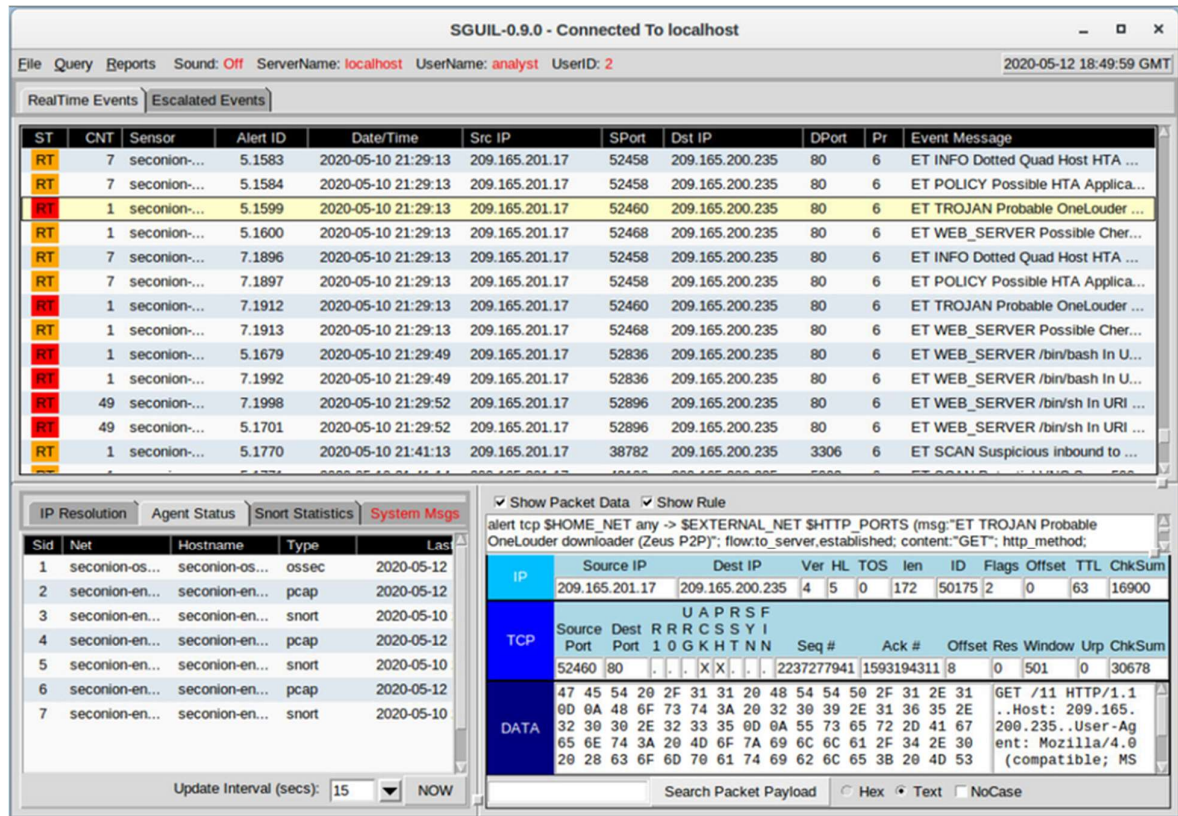
Linux є операційною системою, яку часто вибирають у Центрі безпеки операцій (Security Operations Center, SOC). Ось деякі із причин вибору Linux:

- Linux є ОС із відкритим вихідним кодом (open source) - Будь-яка людина може безкоштовно одержати Linux і змінювати її відповідно до власних потреб. Така гнучкість дозволяє аналітикам та адміністраторам налаштовувати операційну систему спеціально для завдань аналізу безпеки.
- CLI Linux є дуже потужним - Хоча графічний інтерфейс (GUI) робить багато завдань простішими для виконання, він додає складності та потребує більшого обсягу комп'ютерних ресурсів для роботи. Інтерфейс командного рядка (Command Line Interface, CLI) Linux є надзвичайно потужним і дозволяє аналітикам виконувати завдання не тільки безпосередньо в терміналі, але і віддалено.
- Користувач має більший контроль над ОС - Адміністратор у Linux, що відомий як кореневий користувач (root use) або суперкористувач (superuser), має абсолютний доступ до комп'ютера. На відміну від інших ОС, користувач root може змінювати будь-які налаштування комп'ютера кількома натисканнями клавіш. Ця можливість особливо корисна при роботі із функціями низького рівня, як-от мережний стек.
- Дозволяє краще контролювати зв'язок через мережу - Контроль є невід'ємною частиною Linux. Оскільки операційну систему можна змінювати та налаштовувати практично в усьому, це чудова платформа для створення мережних програм. Це також причина, чому багато хороших мережних програмних засобів доступні лише для Linux.

Linux y SOC

Гнучкість, що надається у Linux, є чудовою функцією для SOC. Вся операційна система може бути адаптована, щоб стати ідеальною платформою для аналізу безпеки. Наприклад, адміністратори можуть додавати до ОС лише необхідні пакети програм, що робить її негроміздкою та ефективною.

На рисунку наведено Sguil, яка є консоллю аналітика кібербезпеки у спеціальній версії Linux із назвою Security Onion.



ПЗ для захоплення мережних пакетів (Network packet capture software)

- Важливий інструмент для аналітика SOC, оскільки це дає змогу спостерігати та розуміти кожну деталь мережної транзакції.
- Wireshark – популярний інструмент захоплення пакетів.

Інструменти аналізу шкідливих програм (Malware analysis tools)

Ці інструменти дозволяють аналітикам безпечно запускати та спостерігати за виконанням шкідливого програмного забезпечення без ризику скомпрометувати основну систему.

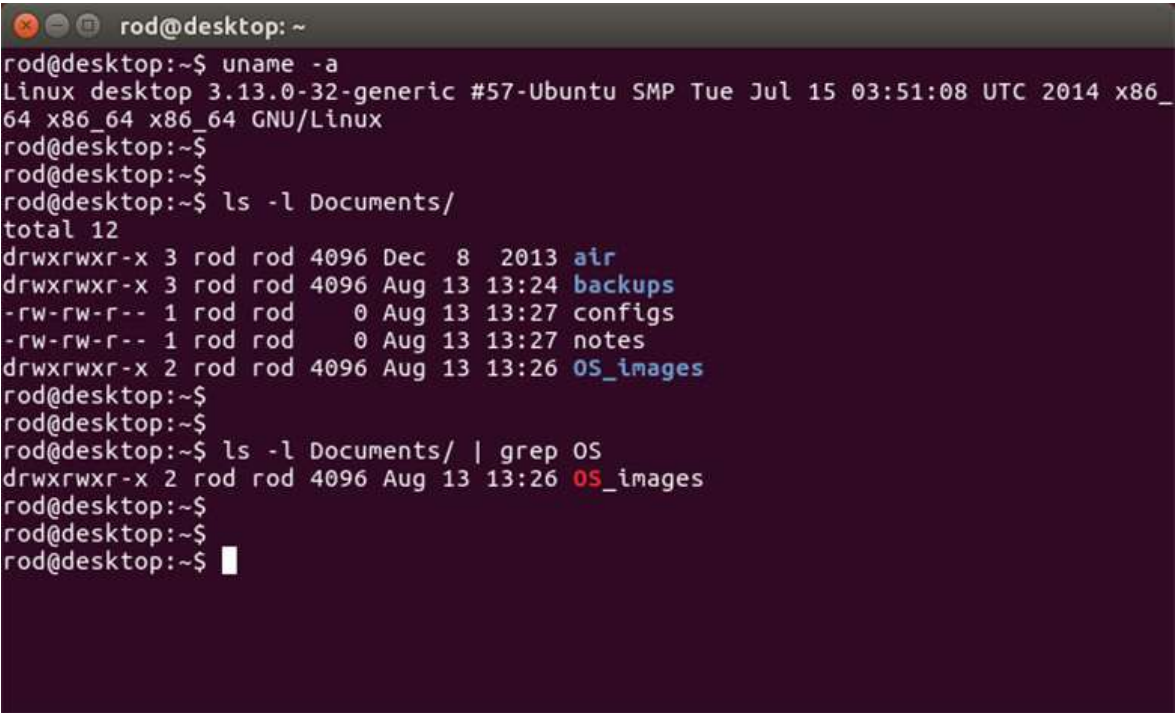
Системи виявлення вторгнень (Intrusion Detection Systems, IDSs)

- Ці інструменти використовуються для моніторингу та перевірки трафіку в реальному часі.
- Якщо будь-який аспект поточного трафіку відповідає будь-якому зі встановлених правил, то виконується заздалегідь визначена дія.

Оболонка Linux

У Linux користувач взаємодіє із ОС за допомогою CLI або GUI. Linux часто запускається у графічному інтерфейсі за замовчуванням. Це приховує CLI від користувача. Один із способів доступу до CLI із графічного інтерфейсу здійснюється за допомогою програми емулятора терміналу. Ці програми надають користувачам доступ до CLI і часто називають сленгом «термінал». У Linux популярними емуляторами терміналу є Terminator, eterm, xterm, konsole і gnome-terminal.

Примітка: Терміни оболонка (shell), консоль, вікно консолі, CLI-термінал, вікно терміналу часто використовуються як синоніми.

A screenshot of a Linux terminal window titled 'rod@desktop: ~'. The terminal shows the output of the 'uname -a' command, which displays system information including the kernel version (3.13.0-32-generic), architecture (x86_64), and date (Tue Jul 15 03:51:08 UTC 2014). Following this, the user runs 'ls -l Documents/' to list files in the Documents directory. The output shows five files: 'air', 'backups', 'configs', 'notes', and 'OS_images', each with its permissions, owner, size, and modification date. Finally, the user runs 'ls -l Documents/ | grep OS', which filters the output to show only the 'OS_images' file.

```
rod@desktop: ~  
rod@desktop:~$ uname -a  
Linux desktop 3.13.0-32-generic #57-Ubuntu SMP Tue Jul 15 03:51:08 UTC 2014 x86_  
64 x86_64 x86_64 GNU/Linux  
rod@desktop:~$  
rod@desktop:~$  
rod@desktop:~$ ls -l Documents/  
total 12  
drwxrwxr-x 3 rod rod 4096 Dec  8  2013 air  
drwxrwxr-x 3 rod rod 4096 Aug 13 13:24 backups  
-rw-rw-r-- 1 rod rod   0 Aug 13 13:27 configs  
-rw-rw-r-- 1 rod rod   0 Aug 13 13:27 notes  
drwxrwxr-x 2 rod rod 4096 Aug 13 13:26 OS_images  
rod@desktop:~$  
rod@desktop:~$  
rod@desktop:~$ ls -l Documents/ | grep OS  
drwxrwxr-x 2 rod rod 4096 Aug 13 13:26 OS_images  
rod@desktop:~$  
rod@desktop:~$  
rod@desktop:~$
```

*Фабріс Беллард створив JSLinux, який дозволяє запускати емульовану версію Linux у браузері. Шукайте його в Інтернеті. Відкрийте консоль Linux у JSLinux і введіть команду **ls**, щоб переглянути поточний вміст каталогу.*

Основні команди

Команди Linux – це програми, створені для виконання певного завдання. Використовуйте команду **man** (скорочено від manual), щоб отримати документацію про команди. Наприклад, **man ls** надає документацію про команду **ls** з керівництва для користувача.

Команда	Опис
mv	Переміщує або перейменовує файли та каталоги
chmod	Змінює права доступу до файлів
chown	Змінює право власності на файл
dd	Копіює дані з входу на вихід
pwd	Відображає назву поточного каталогу
ps	Перелічує процеси, які зараз виконуються в системі
su	Симулює вхід під іншим користувачем або для того, щоб стати суперкористувачем
sudo	Виконує команду від імені суперкористувача за замовчуванням або іншого користувача
grep	Використовується для пошуку певних рядків символів у файлі або інших результатах команд. Щоб шукати вихідні дані попередньої команди, grep потрібно передати в кінці попередньої команди.
ifconfig	Використовується для відображення або налаштування інформації, пов'язаної з мережевою картою. Якщо введено без параметрів, ifconfig відобразить поточну конфігурацію мережевих карт.
apt-get	Використовується для встановлення, налаштування та видалення пакетів у Debian та його похідних.
iwconfig	Використовується для відображення або налаштування інформації, пов'язаної з платою бездротової мережі. Подібно до ifconfig, iwconfig відобразить інформацію про бездротовий зв'язок, якщо її видавати без параметрів.
shutdown	Вимикає систему, можна наказати виконати низку завдань, пов'язаних із завершенням роботи, включаючи перезапуск, зупинку, переведення в режим сну або виключення всіх підключених користувачів.
passwd	Використовується для зміни пароля. Якщо параметри не надано, змінює пароль для поточного користувача.
cat	Використовується для перерахування вмісту файлу та очікує ім'я файлу як параметр.
man	Використовується для відображення документації для певної команди.

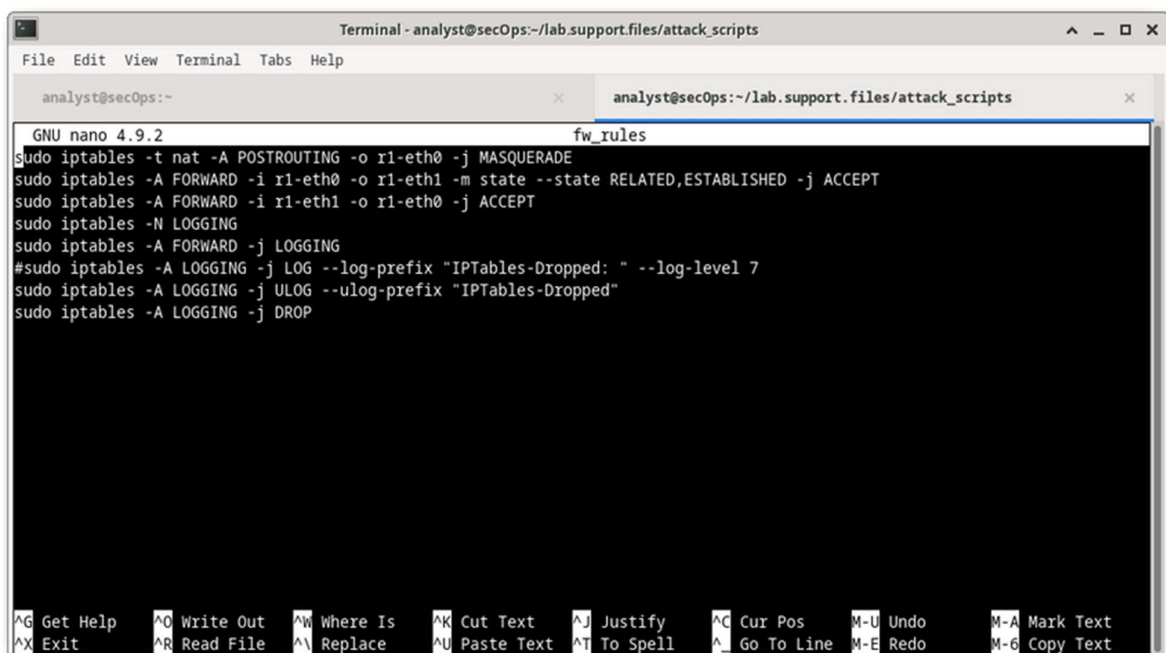
Команди роботи із файлом та каталогом

Багато інструментів командного рядка вбудовано в Linux за замовчуванням. Щоб налаштувати операцію із командою, користувачі можуть передавати параметри та змінні разом із командою.

Команда	Опис
ls	Відображає файли всередині каталогу
cd	Змінює поточний каталог
mkdir	Створює каталог під поточною директорією
cp	Копіює файли з джерела до місця призначення
mv	Переміщує або перейменовує файлів і каталогів
rm	Видаляє файли
grep	Шукає певний рядок символів у файлі або в інших результатах команди
cat	Перераховує вміст файлу та очікує назву файлу як параметр

Linux має велику кількість різноманітних текстових редакторів із різними особливостями та функціями. Деякі текстові редактори містять графічні інтерфейси, а інші – лише інструменти командного рядка. Кожен текстовий редактор містить набір функцій, що призначений для підтримки конкретного типу завдання. Деякі текстові редактори фокусуються на програміста та містять такі функції, як підсвічування синтаксису, круглі та фігурні дужки, перевірку та інші функції, що орієнтовані на програмування.

На рисунку показано **nano**, популярний текстовий редактор командного рядка. Текстові редактори часто використовуються для конфігурації та підтримки системи в Linux.



```
Terminal - analyst@secOps:~/lab.support.files/attack_scripts
File Edit View Terminal Tabs Help
analyst@secOps:~
analyst@secOps:~/lab.support.files/attack_scripts
GNU nano 4.9.2 fw_rules
sudo iptables -t nat -A POSTROUTING -o r1-eth0 -j MASQUERADE
sudo iptables -A FORWARD -i r1-eth0 -o r1-eth1 -m state --state RELATED,ESTABLISHED -j ACCEPT
sudo iptables -A FORWARD -i r1-eth1 -o r1-eth0 -j ACCEPT
sudo iptables -N LOGGING
sudo iptables -A FORWARD -j LOGGING
#sudo iptables -A LOGGING -j LOG --log-prefix "IPTables-Dropped: " --log-level 7
sudo iptables -A LOGGING -j ULOG --ulog-prefix "IPTables-Dropped"
sudo iptables -A LOGGING -j DROP
^G Get Help ^O Write Out ^W Where Is ^K Cut Text ^J Justify ^C Cur Pos M-U Undo M-A Mark Text
^X Exit ^R Read File ^\ Replace ^U Paste Text ^I To Spell ^_ Go To Line M-E Redo M-G Copy Text
```


Сервери, служби та їх порти

У комп'ютері, що є сервером, для різних служб використовуються порти. Порт – це зарезервований мережний ресурс, який використовується службою. Кажуть, що сервер «прослуховує» порт, коли він приєднався до цього порту.

Порт	Опис
20/21	Протокол передачі файлів (FTP)
22	Безпечна оболонка (SSH)
23	Служба віддаленого входу Telnet
25	Простий протокол передачі пошти (SMTP)
53	Система доменних імен (DNS)
67/88	Протокол динамічної конфігурації хоста (DHCP)
69	Тривіальний протокол передачі файлів (TFTP)
80	Протокол передачі гіпертексту (HTTP)
110	Протокол поштового відділення версії 3 (POP3)
123	Протокол мережевого часу (NTP)
143	Протокол доступу до повідомлень Інтернету (IMAP)
161/162	Простий протокол керування мережею (SNMP)
443	HTTP безпечний (HTTPS)

Сервери – це комп'ютери із встановленим програмним забезпеченням, яке дозволяє їм надавати послуги клієнтам у мережі. Є багато видів послуг. Деякі надають клієнтам ресурси, наприклад, файли, як-от файли, повідомлення електронної пошти або веб-сторінки за запитом. Інші служби виконують завдання з обслуговування, як-от управління журналами, керування пам'яттю, сканування диска тощо.

Клієнти – це програми або застосунки, призначені для взаємодії з сервером певного типу. Вони також відомі як клієнтські програми, які використовують чітко визначений протокол для взаємодії із сервером. Веб-браузери – це веб-клієнти, які використовуються для зв'язку з веб-серверами із застосуванням протоколу передавання гіпертексту (Hyper Text Transfer Protocol, HTTP) на порту 80. Клієнт протоколу передавання файлів (File Transfer Protocol, FTP) – це програмне забезпечення, яке використовується для зв'язку із FTP-сервером.

Моніторинг журналів служби

Файли журналів (log files) – це записи, які комп'ютер зберігає для відстеження важливих подій. Події, що пов'язані із ядром, службами та програмами, всі вони записуються у файли журналу. Для адміністратора дуже важливо періодично переглядати журнали комп'ютера для перевірки робочого стану. Контролюючи файли журналу Linux, адміністратор отримує чітке уявлення про продуктивність комп'ютера, стан безпеки та будь-які інші проблеми.

Файл журналу Linux	Опис
/var/log/messages	Цей каталог містить загальні журнали активності комп'ютера.
/var/log/syslog (Debian)	Здебільшого він використовується для зберігання інформаційних і некритичних системних повідомлень.
/var/log/auth.log	Цей файл зберігає всі події, пов'язані з автентифікацією, на комп'ютерах Debian і Ubuntu. У цьому файлі можна знайти все, що стосується механізму авторизації користувача.
/var/log/secure	Цей каталог використовується комп'ютерами RedHat і CentOS замість /var/log/auth.log. Він також відстежує входи sudo, входи SSH та інші помилки, зареєстровані SSSD.
/var/log/boot.log	Цей файл зберігає інформацію, пов'язану з завантаженням, і повідомлення, зареєстровані під час процесу запуску комп'ютера.
/var/log/dmesg	Цей каталог містить повідомлення кільцевого буфера ядра. Тут записується інформація про апаратні пристрої та їх драйвери.
/var/log/kern.log	Цей файл містить інформацію, зареєстровану ядром.
/var/log/cron	Cron — це служба, яка використовується для планування автоматизованих завдань у Linux, і цей каталог зберігає її події. Щоразу, коли виконується заплановане завдання (також називається завданням cron), уся його відповідна інформація, включаючи виконання тут зберігаються повідомлення про стан і помилки.
/var/log/mysql.log	Це файл журналу MySQL. Усі повідомлення про налагодження, помилки та успіхи, пов'язані з процесом mysqld і демоном mysqld_safe, реєструються тут.

Типи файлових систем у Linux

Існує багато різних типів файлових систем, що відрізняються за своїми характеристиками: швидкістю, гнучкістю, безпеки, розміром, структурою, логіки тощо. Адміністратор вирішує, який тип файлової системи найкраще підходить для операційної системи та файлів, які він буде зберігати.

ext2 (друга розширена файлова система)

- Друга розширена файлова система ext2 була файловою системою за замовчуванням у кількох основних дистрибутивах Linux, доки її не замінила ext3.
- ext2 все ще є кращою файловою системою для флеш-носіїв, тому що відсутність журналу збільшує продуктивність і мінімізує кількість записів.
- Оскільки пристрої флеш-пам'яті мають обмежену кількість операцій запису, мінімізація таких операцій збільшує термін служби пристрою.

ext3 (третя розширена файлова система)

- Третя розширена файлова система ext3 – це файлова система із підтримкою журналу, яка розроблена для вдосконалення існуючої файлової системи ext2.
- Журнал – це основна функція, яка додана до ext3, – це технологія, що використовується для мінімізації ризику пошкодження файлової системи у випадку раптової втрати живлення.
- Файлові системи зберігають журнал (або log) усіх змін у файловій системі, які повинні бути зроблені.
- Якщо в комп'ютері відбувся збій до завершення змін, журнал може бути використано для відновлення чи виправлення будь-яких можливих проблем, що виникли внаслідок цієї аварії.
- Максимальний розмір файлової системи ext3 32 TB.

ext4 (четверта розширена файлова система)

- Четверта розширена файлова система ext4 – розроблена як спадкоємець ext3, ext4 була створена на основі ряду розширень для ext3.
- Хоча розширення покращували продуктивність ext3 і збільшували підтримувані розміри файлів, розробники ядра Linux були стурбовані проблемами стабільності та висловлювалися проти додавання розширень до стабільної ext3.
- Проект ext3 був розділений на два; один зберігався і розвивався як ext3, а інший, названий ext4, приєднав згадані розширення.

NFS (Мережева файлова система)

- NFS – мережна файлова система, що дозволяє отримувати доступ до файлів через мережу.
- З точки зору користувача, для нього немає різниці між доступом до файлу, що зберігається локально або на іншому комп'ютері в мережі.
- NFS – це відкритий стандарт, який дозволяє будь-кому реалізовувати його.

CDFS (Файлова система компакт-дисків)

CDFS – файлова система компакт-дисків, була створена спеціально для оптичних дисків.

Система обміну файлами

- Файлова система підкачки використовується Linux при вичерпанні обсягу оперативної пам'яті.
- Технічно – це розділ віртуальної пам'яті, який не має певної файлової системи, однак має відношення до обговорення файлової системи.
- Коли це відбувається, то ядро переміщує неактивний вміст оперативної пам'яті (RAM) до розділу підкачки на диску.
- Хоча розділи підкачки (також відомі як swap space) можуть бути корисними для комп'ютерів з Linux із обмеженим обсягом пам'яті, вони не повинні розглядатися як основне рішення.
- Розділ підкачки swap зберігається на диску, який має набагато меншу швидкість доступу, ніж оперативна пам'ять.

HFS Plus або HFS+ (Ієрархічна файлова система Plus)

- Файлова система, яку використовує Apple у своїх комп'ютерах Macintosh.
- Ядро Linux містить модуль для монтування HFS+ для операцій читання-запису.

APFS (Файлова система Apple)

Оновлена файлова система, яка використовується на пристроях Apple. Забезпечує надійне шифрування та оптимізована для флеш-пам'яті і твердотільних накопичувачів.

Головний завантажувальний запис (MBR)

- Розташована у першому секторі диску комп'ютера, MBR зберігає всю інформацію про організацію файлової системи.
- MBR швидко передає керування функції завантаження, яка завантажує ОС.

Монтування (Mounting) – це термін, який використовується для процесу призначення каталогу певного розділу. Після успішної операції монтування файлова система, що міститься в розділі, доступна через вказаний каталог. У цьому контексті каталог називається точкою монтування для цієї файлової системи. Користувачі Windows можуть бути знайомі із подібною концепцією; буква диска.

Наведено результат виконання команди **mount**, запущеної на віртуальній машині Cisco CyberOPS VM.

```
[analyst@secOps ~]$ mount
proc on /proc type proc (rw,nosuid,nodev,noexec,relatime)
sys on /sys type sysfs (rw,nosuid,nodev,noexec,relatime)
dev on /dev type devtmpfs (rw,nosuid,relatime,size=494944k,nr_inodes=123736,mode=755)
run on /run type tmpfs (rw,nosuid,nodev,relatime,mode=755)
/dev/sda1 on / type ext4 (rw,relatime)
```

Ролі Linux та права доступу до файлів

У Linux більшість системних об'єктів розглядаються як файли. Для того, щоб організувати систему та захистити її в межах комп'ютера, Linux використовує права доступу до файлів. Права доступу до файлів вбудовані у структуру файлової системи та забезпечують механізм визначення дозволів для кожного файлу. Кожен файл у Linux має свої права доступу, визначаючи дії, які власник, група та інші можуть виконувати із файлом. Можливими правами доступу є: читання (Read), запис (Write) та виконання (Execute). Команда `ls` із параметром `-l` містить додаткову інформацію про файл.

```
[analyst@secOps ~]$ ls -l space.txt
-rwxrw-r-- 1 analyst staff 253 May 20 12:49 space.txt
(1) (2) (3)(4) (5) (6) (7)
```

Перше поле результату відображає права доступу, пов'язані з `space.txt` `-rwxrw-r--`. Права доступу до файлу завжди відображаються за порядком у розділах: Користувач (User), Група (Group) та Інші (Other).

Файл `space.txt` має такі права доступу:

- Типе (-) означає, що це файл. Для каталогів першою буде "d", замість тире.
- Перший набір символів права доступу до файлу користувача (rwx). Користувач `analyst`, якому належить файл, може читати (Read), записувати (Write) та запускати (Execute) цей файл.
- Другий набір символів – це права доступу для групи (rw-). Група `staff`, що є власником файлу, має такі права доступу до файлу, як читання (Read) та запис (Write).
- Третій набір символів прав доступу для будь-якого іншого користувача або групи (r--). Будь-який інший користувач або група на цьому комп'ютері може тільки читати (Read) цей файл.

Друге поле визначає кількість жорстких посилань на файл (число 1 після прав доступу до файлу). Жорстке посилання створює інший файл з іншою назвою, який пов'язаний із тим самим місцем у файловій системі (називається `inode` – індексний вузол). Це відрізняється від символічного посилання, яке обговорюється на наступній сторінці.

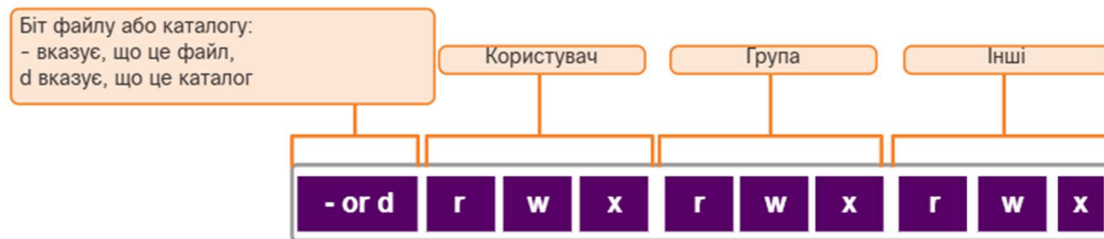
У третьому та четвертому полях відображається користувач (`analyst`) та група (`staff`), які відповідно володіють цим файлом.

П'яте поле відображає розмір файлу в байтах. Файл `space.txt` має 253 байти.

Шосте поле відображає дату та час останньої модифікації.

Сьоме поле відображає ім'я файлу.

На рисунку показано розподіл прав доступу до файлу у Linux.



Двійкові	Вісімкові	Дозвіл	Опис
000	0	---	Немає доступу
001	1	--x	Тільки для виконання
010	2	-w-	Тільки для запису
011	3	-wx	Запис і виконання
100	4	r--	Тільки для читання
101	5	r-x	Читання і виконання
110	6	rw-	Читання й запис
111	7	rxw	Читання, запис і виконання

Права доступу до файлу є фундаментальною частиною Linux і не можуть бути порушені. Користувач має лише права на файл, які надаються правами доступу до файлу. Єдиним користувачем, який може перевизначити права на файл в ОС Linux, є root-користувач (root user). Оскільки root-користувач має повноваження перепризначати права доступу до файлу, то він має право на запис в будь-який файл. Оскільки все розглядається як файл, root-користувач користується повним контролем над комп'ютером з ОС Linux. Перед виконанням технічних і адміністративних завдань часто потрібен доступ користувача із root-правами. Через повноваження root-користувача, облікові дані root повинні використовувати надійні паролі та не надаватися нікому, крім системних адміністраторів та інших користувачів відповідного рівня.

Система X Window

Графічний інтерфейс (GUI), що присутній на більшості комп'ютерів Linux, базується на системі X Window. Також відомої як X або X11, X Window – це віконна система, що призначена для забезпечення базової структури GUI. X містить функції для розтягування та переміщення вікон на дисплеї, взаємодії із мишею та клавіатурою.

X працює як сервер, який дозволяє віддаленому користувачеві використовувати мережу для з'єднання, запуску графічної програми та відкриття графічного вікна на віддаленому терміналі.

Збереження системних оновлень

Відомі, як патчі (patches), оновлення ОС періодично випускаються компаніями для усунення будь-яких відомих вразливостей в їхніх операційних системах. Хоча компанії мають плани оновлень, випуск незапланованих оновлень ОС може статися, коли в коді ОС виявлено серйозну вразливість. Сучасні операційні системи інформують користувача, якщо оновлення доступні для завантаження та встановлення, але користувач може в будь-який час сам перевірити наявність оновлень.

Завдання	Arch	Debian / Ubuntu
Встановити іменний пакет	pacman -S	apt install
Видалити іменний пакет	pacman -Rs	apt remove
Оновити локальний пакет	pacman -Syu	apt-get update
Оновити всі наразі встановлені пакети	pacman -Syu	apt-get upgrade

Процеси та розгалуження

Процес – це запущений на виконання екземпляр комп'ютерної програми.

Розгалуження (forking) – це метод, який використовує ядро для того, щоб процес створював власні копії.

Команда	Опис
ps	Використовується для переліку процесів, запущених на комп'ютері під час його виклику. Йому можна наказати відображати запущені процеси, які належать поточному користувачеві чи іншим користувачам. Для переліку процесів не потрібні привілеї адміністратора, а для завершення або модифікації процесів інших користувачів потрібні.
top	Використовується для переліку запущених процесів, але на відміну від ps, top продовжує динамічно відображати запущені процеси. Натисніть q, щоб вийти з верхньої частини.
kill	Використовується для зміни поведінки певного процесу. Залежно від параметрів, kill видалить, перезапустить або призупинить процес. У багатьох випадках користувач запустить ps або top перед виконанням kill.

Перевірка на руткіти

Руткіт (rootkit) – це набір програмних засобів, призначених для збільшення привілеїв користувача, або надання доступу до тієї частини програмного забезпечення, що, як правило, не допускається. Руткіти також часто використовуються для створення "чорного ходу" (backdoor) на комп'ютері, що був скомпрометований.

chkrootkit – це популярна програма на базі Linux, призначена для перевірки наявності на комп'ютері відомих руткітів. Це скрипт оболонки (script), який використовує загальні інструменти Linux, як-от strings та grep для порівняння сигнатур основних програм. Він також шукає розбіжності, оскільки він переглядає файли системи у /proc, порівнюючи їх сигнатури, що були знайдені там у результаті виконання команди.

Хоча це є корисним, але майте на увазі, що програми для перевірки наявності руткітів не є надійними на 100%

Конвеєрні команди

Хоча інструменти командного рядка, як правило, призначені для виконання конкретного, чітко визначеного завдання, багато команд можна комбінувати для виконання більш складних завдань за допомогою технології, відомої як поєднання команд – конвеєр (piping). Названий за своїм визначальним символом "труба" (pipe) (|), "трубопровід" конвеєр складається із ланцюжків команд, які передають результат виконання однієї команди на вхід іншої. Наприклад, команда ls використовується для відображення всіх файлів і підкаталогів певного каталогу. Команда grep здійснює порівняльний пошук у файлі або тексті, шукаючи вказану частину рядка. Після пошуку, grep відображає тільки ті файли з усього вмісту підкаталогу, в яких було знайдено необхідну частину рядка.

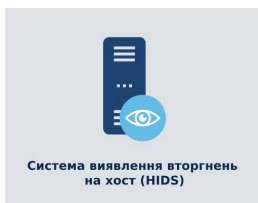
Дві команди, ls та grep, можуть бути об'єднані для фільтрації результату виконання команди ls. Це показано у результаті виконання команд `ls -l | grep host` і `ls -l | grep file`.

Безпека кінцевих точок

Рішення на основі хоста – це програмний застосунок, який виконується на локальному комп'ютері (або кінцевій точці) для його захисту.



Брандмауер на основі хоста працює на пристрої, щоб обмежити вхідну та вихідну мережну активність для цього пристрою. Він може дозволяти або забороняти трафік між пристроєм і мережею. Програмний брандмауер перевіряє та фільтрує пакети даних, щоб захистити пристрій від зараження. Брандмауер Windows, встановлений за замовчуванням під час інсталяції Windows, є прикладом програмного брандмауера.



Програмне забезпечення HIDS встановлюється на пристрої або сервері для моніторингу підозрілої активності. HIDS відстежує системні виклики та доступ до файлової системи для виявлення шкідливих зловмисних запитів. HIDS також може відстежувати інформацію про конфігурацію пристрою, яка зберігається в системному реєстрі. HIDS зберігає всі дані журналу локально. Цей процес вимагає ресурсів, тому може вплинути на продуктивність системи.



HIPS – це програмне забезпечення, яке відстежує пристрій на наявність відомих атак і аномалій (відхилення в пропускній здатності, протоколах і портах) або знаходить червоні прапорці, оцінюючи фактичні протоколи в пакетах. Якщо вона виявляє зловмисну активність, інструмент HIPS може надіслати вам тривогу, зареєструвати шкідливу активність, скинути з'єднання та/або скинути пакети.



Інструменти DLP забезпечують централізований спосіб того, що конфіденційні дані не будуть знищені, викрадені або доступні неавторизованим користувачам.



EDR – це інтегроване рішення безпеки, яке безперервно відстежує та збирає дані з кінцевого пристрою. Потім воно аналізує дані та реагує на будь-які виявлені загрози. Антивірус може лише блокувати загрози, тоді як EDR може блокувати і знаходити загрози на пристрої.

Шифрування хоста

Функція Windows Encrypting File System (EFS) дозволяє користувачам шифрувати файли, папки або весь жорсткий диск.

Функція Full disk encryption (FDE) шифрує весь вміст диска (тимчасові файли та пам'ять). Microsoft Windows використовує BitLocker для FDE.



Перед використанням BitLocker користувачеві необхідно увімкнути Trusted Platform Module (TPM) в BIOS. TPM – це спеціалізована мікросхема на материнській платі, яка зберігає інформацію про хост-систему, а саме ключі шифрування, цифрові сертифікати і паролі. Якщо TPM ввімкнено, BitLocker може використовувати TPM-чип.

BitLocker To Go шифрує знімні носії. BitLocker To Go не використовує TPM-чип, але все одно шифрує дані, вимагаючи пароль для їх дешифрування. У той же час самошифрування пристрою автоматично шифрує всі дані на диску, щоб запобігти доступу зломисників до даних через операційну систему.

Цілісність завантаження



Прошивка (Firmware) – інструкції програмного забезпечення щодо основних функцій комп'ютера – зберігається на чипі пам'яті на материнській платі. Базова система введення/виведення (BIOS) – це перша програма, яка запускається під час увімкнення комп'ютера.



Цілісність завантаження гарантує, що системі можна довіряти, і вона не була змінена під час завантаження операційної системи. Secure Boot — це стандарт безпеки, який гарантує, що пристрій завантажується за допомогою надійного програмного забезпечення.



Контрольоване завантаження (Measured Boot) забезпечує більш надійну перевірку, ніж безпечне завантаження (Secure Boot). Measured Boot перевіряє кожен завантажувальний компонент, починаючи з мікропрограми і закінчуючи завантаженими драйверами, та зберігає результат в TPM-чипі, створюючи журнал.

Функції безпеки системи Apple

Як ми знаємо, дистрибутиви Windows і Linux містять функції безпеки, призначені для захисту кінцевих точок. Apple надає системне обладнання та функції безпеки macOS, які також пропонують надійний захист кінцевої точки.

Апаратне забезпечення, орієнтоване на безпеку

Апаратна платформа має розширені функції безпеки, такі як спеціальний процесор, завантажувач і спеціальний механізм шифрування AES. Ці функції включені в спеціальну систему на чіпі під назвою Secure Enclave.

Зашифроване сховище

Шифрування сховища даних Apple Data Protection і FileVault підтримується апаратним механізмом шифрування AES. Це дозволяє шифрувати та розшифровувати файли під час їх запису чи читання, не відкриваючи ключі шифрування головному ЦП, операційній системі чи запущеним програмам.

Безпечний запуск

Завантажувальний ПЗУ захищає апаратне забезпечення низького рівня та дозволяє запускати лише справжнє та незмінене програмне забезпечення ОС Apple.

Безпека біометричних даних

Дані біометричної автентифікації обробляються апаратною системою безпеки. Це відокремлює його від ОС і запущеного прикладного програмного забезпечення, включаючи зловмисне програмне забезпечення.

XProtect

Технологія захисту від зловмисного програмного забезпечення XProtect запобігає запуску зловмисного програмного забезпечення за допомогою виявлення зловмисного програмного забезпечення на основі сигнатур. Він також попереджає користувачів про наявність шкідливого програмного забезпечення та надає можливість видалити виявлені файли шкідливого програмного забезпечення.

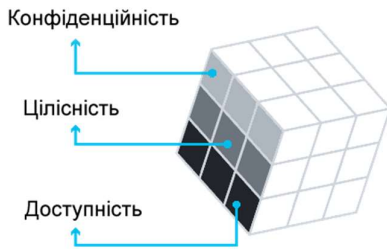
Інструмент видалення шкідливих програм (MRT)

Інструмент видалення зловмисного програмного забезпечення (MRT) виявляє та видаляє наявне зараження шкідливим програмним забезпеченням, коли Apple автоматично оновлює правила виявлення. Він також відстежує зараження шкідливим програмним забезпеченням під час перезавантаження системи та входу користувача.

Привратник

Привратник гарантує, що можна встановлювати лише автентичне програмне забезпечення з цифровим підписом, створене нотаріально завіреним розробником програмного забезпечення Apple.

Куби кібербезпеки



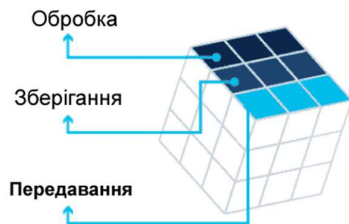
1. Принципи безпеки

Конфіденційність даних запобігає розкриттю інформації неавторизованим особам, ресурсам або процесам.

Цілісність даних стосується точності, узгодженості та достовірності даних.

Доступність даних гарантує, що інформація доступна авторизованими користувачами у разі потреби.

Для запам'ятовування цих трьох принципів зручно використовувати аббревіатуру КІД (англ. CIA - Confidentiality, Integrity, Availability).

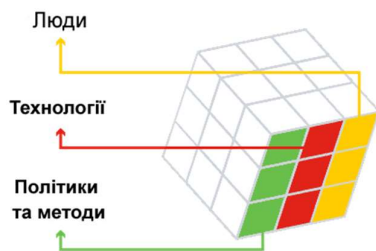


2. Стани даних

Домен кіберпростору містить значну кількість критично важливих даних. Але в якому вони стані? Другий вимір куба кібербезпеки представляє три можливих стани даних:

- Дані під час передавання
- Дані в стані спокою або при зберіганні
- Дані у процесі обробки

Ефективна кібербезпека вимагає захисту даних у всіх трьох станах. Ми не можемо зосередитися лише на захисті даних, які обробляються, або лише даних, що зберігаються.



3. Запобіжні засоби

Третій вимір куба кібербезпеки визначає стовпи, на яких будується захист кібербезпеки, щоб захистити дані та інфраструктуру в цифровій сфері.

Це технології, політики та методи, а також покращення освіти, навчання та обізнаності людей.

Фахівці з кібербезпеки повинні використовувати низку різноманітних доступних їм навичок та дисциплін при захисті даних та інфраструктури в кіберпросторі.

Дані у стані спокою

Термін 'Дані в стані спокою' стосується даних, які зберігаються. Простіше кажучи, це такий стан даних, коли жоден користувач або процес не звертається до них, не запитує чи не змінює їх.

Безпосередньо під'єднане сховище даних (Direct-Attached Storage, DAS)

Цей тип накопичувача під'єднується до комп'ютера. Прикладом такого сховища є жорсткий диск або USB-накопичувач. За замовчуванням системи не налаштовані на спільне з іншими комп'ютерами в їхній мережі використання DAS.

Надлишковий масив незалежних дисків (Redundant Array of Independent Disks, RAID)

Ці професійні рішення для зберігання даних використовують декілька жорстких дисків у масиві, що є методом об'єднання кількох дисків, щоб операційна система розглядала їх як один диск. RAID забезпечує підвищену продуктивність і відмовостійкість.

Мережне сховище даних (Network Attached Storage, NAS)

Це під'єднаний до мережі пристрій зберігання, який дозволяє авторизованим користувачам мережі зберігати та читати дані з централізованого місця розташування. Пристрої NAS гнучкі й масштабовані, що дозволяє адміністраторам збільшувати їх ємність за необхідності.

Мережа зберігання даних (Storage Area Network, SAN)

Архітектура SAN – це мережна система зберігання даних. Системи SAN під'єднуються до мережі за допомогою високошвидкісних інтерфейсів, що дозволяє підвищити продуктивність та дає можливість під'єднувати кілька серверів до централізованого репозиторію дискового сховища.

Хмарне сховище

Це вид віддаленого сховища, який використовує простір на накопичувачах в дата-центрі провайдера, доступ до даних може бути організований з будь-якого комп'ютера з доступом до Інтернету, як правило, за підпискою. Google Drive, iCloud і Dropbox - все це приклади постачальників хмарних сховищ.

Дані в стані спокою також включають дані резервних копій (коли вони не записуються чи не передаються). Резервні копії можна створювати вручну або автоматично. Щоб підвищити безпеку та зменшити втрату даних, організаціям слід обмежити типи даних, що зберігаються на безпосередньо під'єднаних пристроях зберігання.

Методи передавання даних

Дані при передаванні – це другий стан даних, який ми збираємося розглянути, він стосується даних, які просто передаються — вони не перебувають у стані спокою та не використовуються.

Перенесення даних вручну (sneaker net)

Sneaker net використовує знімні носії для фізичного переміщення даних з одного комп'ютера на інший. Організації ніколи не зможуть повністю відмовитися від використання сітки для кросівок як способу передачі даних між пристроями.

Дротові мережі

Дротові мережі включають мідні та волоконно-оптичні кабелі та можуть обслуговувати локальну мережу (LAN) або покривати великі відстані у глобальних мережах (WAN).

Бездротові мережі

Бездротові мережі використовують радіохвилі для передавання даних. Бездротові мережі замінюють дротові мережі, оскільки вони стають швидшими та здатні обробляти більше трафіку. Бездротові мережі збільшують кількість гостей користувачів, які під'єднуються до них з мобільних пристроїв у мережах невеликих/домашніх офісів (Small Office/Home Office, SOHO) і корпоративних мережах. Це також збільшує поле для атаки на мережу.

Проблеми передавання даних

Захист даних при передаванні є однією з найскладніших задач фахівця з кібербезпеки.

Захист конфіденційності даних при передаванні

Фахівці з кібербезпеки повинні вживати заходів для захисту даних під час передавання, наприклад, впроваджувати VPN, використовувати SSL і IPsec, а також інші різноманітні відповідні методи шифрування даних.

Захист цілісності даних при передаванні

Фахівці з кібербезпеки впроваджують системи підтримки цілісності даних, які перевіряють достовірність і автентичність переданих даних. Ці системи включають, наприклад, хешування та резервування даних.

Захист доступності даних при передаванні

Простий мобільний пристрій може видавати себе за локальну бездротову точку доступу і обманним шляхом змушувати користувачів, які нічого не підозрюють, зв'язуватися з ним. Потім кіберзлочинець може перехопити авторизоване з'єднання із захищеною службою або пристроєм. У міру того, як дані передаються на пристрій жертви і з нього, кіберзлочинець може перехопити і навіть видалити їх, що вплине на їх доступність.

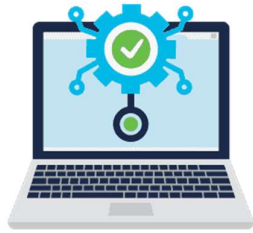
Дані у процесі обробки

У процесі обробки дані перебувають під час початкового введення, зміни, обчислення або виведення. Це стан, у якому перебувають дані, коли вони не передаються і не перебувають у стані спокою — простіше кажучи, це дані, які обробляються.



Введення даних

Захист цілісності даних починається з початкового введення даних. Організації використовують кілька методів збору даних, кожен з яких створює потенційну загрозу цілісності даних: введення даних, сканування форм, завантаження файлів і збір даних з датчиків.



Зміна даних

Модифікація даних – це будь-які зміни, внесені до початкових даних, наприклад, користувачі, які вручну змінюють дані, а також програми, які обробляють та змінюють дані. Ці зміни є навмисними.

Процеси, такі як кодування/декодування, компресія/декомпресія і шифрування/дешифрування, теж є прикладами модифікації даних. Але зміни в даних також можуть бути й ненавмисними або зловмисними.

Виведення даних



Під виведенням даних мається на увазі передавання даних на пристрої виводу, такі як принтери, електронні дисплеї та динаміки. Точність вихідних даних має вирішальне значення, оскільки виведені дані надають інформацію та впливають на прийняття рішень.

Прикладами пошкодження вихідних даних можуть бути неправильне використання обмежувачів даних, невірні параметри з'єднання і невідповідно налаштовані принтери.

Створення культури обізнаності про кібербезпеку

Інвестування великих грошей у технології не матиме ніякого значення, якщо люди в організації не навчені кібербезпеці.



Освіта і навчання

- Зробіть тренінг з питань безпеки необхідним елементом для початку роботи у компанії.
- Враховуйте обізнаність з питань безпеки при прийомі на роботу або при оцінюванні працездатності
- Проводьте очні навчальні заняття з використанням гейміфікації та активностей (наприклад, сценарії захоплення прапора).



Програми підвищення рівня обізнаності про безпеку

Активна програма інформування про безпеку залежить від:

- Середовища та мережі організації.
- Рівня загрози.
- Характеру і вимог до даних, якими володіє організація.

Люди – це перша лінія захисту в кібербезпеці, і

кожна організація сильна настільки, наскільки сильна найслабша її ланка. Кожен працівник організації повинен знати про її політики безпеки та застосовувати їх у своїй повсякденній діяльності.

Політики

Політика безпеки визначає цілі безпеки, правила поведінки та системні вимоги, яких слід дотримуватися.

Комплексна політика безпеки виконує кілька завдань:

- Демонструє серйозне ставлення організації до безпеки.
- Встановлює правила очікуваної поведінки.
- Забезпечує послідовність роботи системи та придбання, використання й обслуговування програмного та апаратного забезпечення.
- Визначає юридичні наслідки порушень.
- Надає фахівцям з безпеки підтримку керівництва.